Udyam Digital: Privacy & Security Note

Accel Business · YTL Hackathon 2026 · Enterprise Track A

Udyam Digital uses synthetic data for demonstration, yet follows key principles of India's Digital Personal Data Protection (DPDP) Act, 2023. This note covers implemented safeguards and planned improvements; it is not a legal compliance certification.

1. Consent & Data Collection

- Versioned English or Hindi privacy notice before Smart KYC: purposes, retention, withdrawal.
- Separate consent for mandatory document verification and optional anonymised service improvement.
- KYC uploads and submissions are blocked without active consent.
- Withdrawing consent deletes stored KYC results and extracted document details.
- Only required information is collected; Aadhaar is not requested.

2. Document & Data Protection

- Document photos are processed in memory with RapidOCR, never stored on disk; 10 MB limit.
- Extracted document details stay in memory for up to 30 minutes.
- The database holds only KYC verdicts, check results and masked identifiers, not full IDs or addresses.
- GSTIN, Udyam, identity and phone numbers are masked in APIs, back-office screens and logs.
- Phone numbers are Fernet-encrypted at rest; tracker PINs are salted PBKDF2-SHA256 hashes.

3. External AI & Data Sharing

The advisor uses Groq and Gemini, with a rules-only fallback.

- Only business chat messages, the business profile and application-generated reply text are shared.
- GSTINs are replaced, and Udyam and phone numbers masked, before transmission.
- Documents, photos, OCR results, identity numbers, contact details and orders are never sent to LLMs.
- Eligibility and pricing come from deterministic server-side rules; AI cannot change or promise prices.

4. Access Control & Hosting

- The order tracker needs an order ID and random four-digit PIN, with rate limiting on failed attempts.
- Back-office routes need a passcode header, checked with constant-time comparison.
- Runs on Google Cloud Run in Mumbai (asia-south1) over HTTPS.
- API secrets are in Google Secret Manager; the container runs as non-root.
- SQLite database, with phone numbers encrypted at rest.

5. Retention & Current Limitations

Stated retention is 180 days after activation or 30 days after rejection; automated deletion is not yet implemented. The demo SQLite database is ephemeral, wiped on restart, redeployment or scale-to-zero.

6. Planned Production Improvements

Before production deployment, we plan to introduce:

- DigiLocker-based document verification and Aadhaar e-sign.
- Role-based staff accounts, SSO and an append-only audit log.
- Managed encrypted database, Cloud KMS and automated retention enforcement.
- Stronger security headers, restricted API documentation and disabled demo mode.
- Privacy impact assessment, LLM data-processing agreements, grievance and breach processes.

All businesses, individuals, identifiers and documents used in the prototype are synthetic.